

NotPetya: Maersk and the Global Endpoint Apocalypse

A forensic case study in supply chain compromise, lateral movement, and the catastrophic cost of unpatched endpoints. 27 June 2017 — the day 49,000 machines died in seven minutes.

CASE STUDY

THREAT INTELLIGENCE



Background

The Attack That Rewrote Enterprise Risk

On 27 June 2017, a malware outbreak designated **NotPetya** propagated across global networks with unprecedented velocity. Attributed by the UK NCSC, the Australian Signals Directorate, and US CISA to the Russian state-sponsored **Sandworm** threat group, it was not ransomware — it was a **wiper masquerading as ransomware**. The encryption was deliberately destructive; no recovery path existed by design.

The initial delivery vector was a compromised update to **M.E.Doc**, Ukrainian accounting software mandated for virtually every organisation conducting international transactions in Ukraine. The supply chain was the entry point. The endpoint estate was the target.

Global Damage Scorecard

\$10B+

Estimated global losses

49K

Maersk endpoints destroyed

7min

Time to total IT collapse

Scale of Impact

Who Was Hit — and How Hard

NotPetya achieved a degree of collateral damage that no prior cyberattack had approached. The following organisations represent the headline casualties.

Maersk

US\$300M declared losses. 49,000 endpoints, 4,000 servers, 2,500 applications destroyed globally. All domain controllers wiped. Global shipping operations paralysed.

Merck

US\$870M in losses. Manufacturing halted. Insurance litigation over "act of war" exclusion clauses became landmark case law.

FedEx / TNT Express

US\$400M losses. TNT Australia operations disrupted for weeks. Customer parcel tracking and depot systems remained offline for months.

ANZ Region

Cadbury Hobart manufacturing halted. TNT Express Australia severely degraded. AU Cyber Security Centre issued direct advisory bulletins. Smaller organisations with Ukrainian trading partners widely affected.



Root Cause Analysis

The Five-Step Kill Chain

NotPetya's devastation was not accidental — it followed a precise, replicable sequence. Understanding each step maps directly to the controls that could have broken the chain.

Kill Chain: Step by Step



Step 1 — Supply Chain Compromise

Sandworm compromised the M.E.Doc update server and pushed a backdoored update to all clients. Every organisation running M.E.Doc received the implant as a trusted software update.



Step 2 — Initial Access

The backdoored update established persistent access on every M.E.Doc client endpoint. For organisations with broad Ukrainian operations, this meant hundreds or thousands of compromised machines immediately.



Step 3 — EternalBlue & Mimikatz

NotPetya scanned for SMB-reachable Windows machines. Unpatched hosts (MS17-010, patch available 110 days prior) were exploited directly. Patched hosts were attacked via Mimikatz, extracting domain admin credentials from LSASS memory.



Step 4 — Living Off the Land

Armed with domain admin credentials, NotPetya authenticated to further machines using *legitimate* Windows tools — PsExec, WMIC, WinRM. Signature-based AV had zero visibility; no malicious binaries were introduced.



Step 5 — Destructive Payload

On each reached machine, NotPetya overwrote the Master Boot Record and encrypted file systems with an algorithm that had no decryption capability. The endpoint became permanently unbootable. 49,000 machines in approximately seven minutes.

The Failure Map: Six Controls That Would Have Changed Everything

Each stage of the kill chain corresponds directly to a control failure. These are not hypothetical improvements — they are documented, available, and actionable disciplines that were absent on 27 June 2017.

Patch Management

MS17-010 had been available for **110 days** before NotPetya detonated. Organisations that had not deployed it gave NotPetya its primary lateral movement vector. ASD ISM patch cadence compliance would have eliminated EternalBlue entirely.

Network Segmentation

No segmentation existed between corporate endpoints, server estates, or geographic regions. Once one endpoint was compromised, SMB-reachable access to the *entire global network* was unrestricted. An architectural failure that amplified the endpoint failure catastrophically.

Least Privilege & Application Control

Users running with local admin rights allowed Mimikatz to access LSASS memory without elevation. Users could execute arbitrary binaries. ASD Essential Eight Application Control — an allow-list — would have prevented NotPetya from executing at all.

Advanced Endpoint Protection (EDR)

No EDR was deployed. Modern EDR detects Mimikatz LSASS access patterns, PsExec/WMIC lateral movement chains, and destructive MBR write operations through behavioural rules — none of which are signature-dependent. AV-only environments were completely blind.

Configuration Enforcement

Credential caching on workstations — the default Windows behaviour that Mimikatz exploits — had not been hardened. LSA Protection was not enabled. Credential Guard was not configured. These are Group Policy or Intune settings, not engineering projects.

Endpoint Hardening

Default Windows configurations permitted SMB inbound across internal networks without restriction. CIS Benchmark hardening restricts SMB to defined subnets and mandates SMB signing — either of which would have materially constrained lateral movement velocity.

The Maersk Recovery

One Offline Domain Controller in Lagos

With every domain controller wiped simultaneously, Maersk had no Active Directory — the identity and authentication backbone for the entire global enterprise. Recovery appeared impossible.

Then they found it. A single domain controller in **Lagos, Nigeria**, had been offline for entirely unrelated reasons at the moment of detonation. It survived. That one accidentally-surviving DC became the seed from which Maersk rebuilt its entire global domain configuration.

The recovery effort required **10 days of round-the-clock work** — deploying 45,000 new PCs, 4,000 new servers, re-imaging 2,500 applications, all while global shipping operations limped forward on paper-based contingency. Andy Powell, then Maersk CISO, has described the experience extensively in subsequent industry talks. It is now the canonical case study in operational resilience and the value of offline, isolated backup infrastructure.

 **The Lesson:** Maersk's survival hinged on an accident of geography and poor IT hygiene — a DC that happened to be offline. Your business continuity plan cannot depend on luck. Offline, network-isolated, cryptographically verified backups of domain infrastructure are a non-negotiable resilience control.

10

Days to rebuild global IT

45K

New PCs deployed

1

DC that saved the company

The Six NotPetya Questions

Every control failure in this case study has a corresponding diagnostic question. As a vCISO or security reviewer, these six questions constitute a comprehensive endpoint security assessment — deliverable in a single working day.

1

Walk the Patching

Show me a Critical patch deployed in the last quarter — from publication to 95% endpoint coverage. Was deployment within ASD ISM SLA? Where are the gaps in the long tail?

2

Walk the Privilege

How many users hold local admin? How many service accounts have interactive logon rights? Is privilege elevation managed via PAM/JIT, or is admin access standing and permanent?

3

Walk the EDR

If Mimikatz ran against LSASS memory on an endpoint right now — what would detect it? What alert would fire? Who would respond, and within how many minutes?

4

Walk the Segmentation

If one endpoint were fully compromised today, what is the SMB-reachable surface from that single machine? Show me on a network diagram. Is east-west movement restricted?

5

Walk the Configuration

Are security baselines applied via Group Policy or Intune? When was the last compliance scan? Are LSA Protection and Credential Guard enabled across the fleet?

6

Walk the Application Control

Is an application allow-list deployed? If not, what is the current ASD Essential Eight Application Control maturity level, and what is the documented path to uplift?

❗ Six questions. Six hours. A comprehensive endpoint security diagnostic grounded in a real-world \$10B threat scenario.

ANZ Local Parallel

HWL Ebsworth: Australia's NotPetya Moment

In **April 2023**, ALPHV/BlackCat ransomware compromised the endpoint estate of **HWL Ebsworth**, one of Australia's largest commercial law firms. The attack enabled the exfiltration of approximately **2.5 million documents** spanning sensitive legal, commercial, and governmental matter files.

The downstream impact extended to **65+ government agencies**, creating a regulatory and liability cascade that remained active in proceedings through 2026. Estimated total damages exceed **A\$120 million**. The breach is on a trajectory to become the most consequential Australian corporate data breach by impact since Medibank Private.

The attack vector — ransomware executing on endpoints with insufficient privilege controls, inadequate EDR coverage, and no application control enforcement — mirrors the NotPetya failure map precisely. The threat actor changed. The control failures did not.

Attack Vector

ALPHV/BlackCat ransomware on insufficiently controlled endpoints

Data Exfiltrated

2.5 million documents including government agency matter files

Downstream Impact

65+ government agencies affected; regulatory proceedings ongoing 2026

Estimated Damages

A\$120M+ — the most significant Australian breach trajectory since Medibank

Practitioner Takeaway

Every Control Has Its NotPetya Moment

NotPetya was not an exotic, nation-state-only threat scenario. It was the consequence of six common, documented, remediable control failures — failures that exist in enterprise environments today, including in Australian government and commercial organisations.

Patch Management 110 days was enough time. SLA discipline saves enterprises. The EternalBlue vector was entirely preventable.	Least Privilege Local admin access handed Mimikatz the keys. Privilege reduction is not a project — it is a standing policy.
EDR Over AV Behavioural detection catches what signatures cannot. Living-off-the-land attacks are invisible to legacy AV.	Segmentation Unrestricted east-west movement turned one compromised endpoint into a global catastrophe. Contain the blast radius.

📌 **The practitioner's obligation:** Use the six NotPetya questions as a repeatable diagnostic. Apply them to every client endpoint review. The questions are the structure. The \$10 billion case study is the justification.